

AegisCare HMS — Data Breach Response Runbook

System	AegisCare HMS / LabTrack v5.16
Document type	Incident Response Runbook
Version	1.0
Date	2026-08-27
Owner	Francis Muhoro
Legal basis	Data Protection Act 2019; Digital Health Act 2023; ODPC Guidelines

This runbook must be followed immediately upon discovery of any actual or suspected personal data breach. Timelines are strict and legally binding.

Notification Deadlines

Authority	Deadline	Contact
ODPC	72 hours from discovery	odpc@odpc.go.ke / 0800 722 522
DHA	48 hours from discovery	dha@health.go.ke
Affected individuals	Without undue delay (if high risk)	Direct contact
Internal escalation	Immediately on discovery	See Step 1 below

Step 1 — Immediate Actions (0–2 Hours)

1.1 Confirm the Incident

- ☐ Determine if this is a confirmed breach or suspected breach
- ☐ Identify what data is involved (PHI, financial, credentials)
- ☐ Identify how many patients/records are affected
- ☐ Identify the source (external attack, internal error, third-party)

1.2 Contain the Breach

- ☐ If system compromise: immediately revoke all active sessions in Supabase
- ☐ If API key exposed: rotate all Supabase keys immediately
- ☐ If Edge Function compromised: disable via Dashboard
- ☐ If database breach: immediately enable Supabase network restrictions
- ☐ Document the time of containment

1.3 Escalate Internally

- ☐ Notify: Francis Muhoro (system owner)
- ☐ Notify: Facility Director / Medical Superintendent
- ☐ Notify: Data Protection Officer (DPO) — once appointed

- ☐ Open an entry in docs/incident-register.md
- ☐ Do NOT delete any logs or evidence

Step 2 — Assessment (2–12 Hours)

2.1 Scope the Breach

Run in **Supabase SQL Editor** to check audit trail:

```
-- What happened in the last 24 hours?
SELECT
table_name,
action,
performed_by,
created_at,
old_data,
new_data
FROM public.audit_log
WHERE created_at > now() - INTERVAL '24 hours'
ORDER BY created_at DESC
LIMIT 100;

-- Check for unusual access patterns
SELECT
    performed_by,
    table_name,
    action,
    COUNT(*) AS action_count
FROM public.audit_log
WHERE created_at > now() - INTERVAL '24 hours'
GROUP BY performed_by, table_name, action
ORDER BY action_count DESC
LIMIT 20;

-- Check break-glass access
SELECT *
FROM public.audit_log
WHERE action = 'BREAK_GLASS'
    AND created_at > now() - INTERVAL '7 days'
ORDER BY created_at DESC;

TO: odpc@odpc.go.ke
SUBJECT: Personal Data Breach Notification – AegisCare HMS – [DATE]
```

2.2 Document Impact

Number of patients affected: _____

Data categories exposed:

- Names / contact details
- National ID numbers
- Medical records / diagnoses
- Financial / billing records
- SHA member numbers
- Prescriptions / lab results

Likely consequence to individuals: Low / Medium / High / Very High

Was data exfiltrated or only accessed?

2.3 Determine Notification Requirement

Risk Level	Action Required
------------	-----------------

Low (no PHI, no exfiltration)	Internal record only
-------------------------------	----------------------

Medium (limited PHI, no exfiltration)	ODPC + DHA notify
---------------------------------------	-------------------

High (PHI exfiltrated, financial data)	ODPC + DHA + individuals
--	--------------------------

Very High (large scale, sensitive)	ODPC + DHA + individuals + public
------------------------------------	-----------------------------------

Step 3 – ODPC Notification (Within 72 Hours)

Deadline: 72 hours from the moment the breach was discovered.

3.1 ODPC Notification Template

Dear Office of the Data Protection Commissioner,

Pursuant to Section 43 of the Data Protection Act, 2019, we hereby notify you of a personal data breach affecting our health management system.

SYSTEM DETAILS:

Organization: [Facility Name]

System: AegisCare HMS v5.16

Data Controller Registration: [ODPC Reg Number – pending]

BREACH DETAILS:

Date/Time of Discovery: [DATETIME]

Date/Time of Breach (if known): [DATETIME]

Date/Time of Containment: [DATETIME]

NATURE OF BREACH:

[Describe what happened – e.g., unauthorized access, accidental disclosure]

DATA INVOLVED:

Categories of data: [list categories]

Approximate number of records: [number]

Approximate number of individuals: [number]

LIKELY CONSEQUENCES:

[Describe risk to individuals]

MEASURES TAKEN:

[Describe containment and remediation steps]

CONTACT:

Name: Francis Muhoro

Role: System Owner / Data Controller

Email: [email]

Phone: [phone]

We will provide a full incident report within 14 days.

Yours faithfully,

Francis Muhoro

AegisCare HMS

4.2 DHA Submission Checklist

Email sent to dha@health.go.ke within 48 hours
Reference number recorded
Full incident report submitted within 14 days
Step 5 – Individual Notification (If High Risk)
If the breach is likely to result in high risk to individuals:

Identify affected patients by querying audit_log
Notify each patient via:
SMS (use send-sms edge function)
Phone call for high-risk cases
Notification must include:
What data was involved
What steps we have taken
What they can do to protect themselves
Our contact details
SMS Notification Template
text

AegisCare Security Notice: We have detected a security incident that may have affected your health records. We have secured the system.
Please call [phone] for more information. Ref: [incident-id]

Step 6 – Recovery and Evidence Preservation
Restore from last verified clean backup
Verify backup integrity before restoring
Document RPO (Recovery Point Objective) achieved
Document RTO (Recovery Time Objective) achieved
Preserve all logs – do NOT delete any audit_log records
Engage forensics if criminal activity suspected

Step 7 – Post-Incident Review (Within 14 Days)
Root cause analysis completed
Full incident report written
ODPC full report submitted (within 14 days)
DHA full report submitted
Security controls reviewed and updated
Staff training updated if human error involved
Incident register updated with resolution
DHA certification team notified of remediation

Emergency Contacts

Role	Name	Contact
System Owner	Francis Muhoro	[phone/email]
Facility Director	[Name]	[phone]
DPO	[TBA – pending appointment]	[TBA]
ODPC Helpline	–	0800 722 522
ODPC Email	–	odpc@odpc.go.ke
DHA Email	–	dha@health.go.ke
Supabase Support	–	support@supabase.com

Incident Register Link

All incidents must be recorded in docs/incident-register.md.